

PCI DSS v4.0 Official Quick Reference Guide: Token Vaults & Cardholder Data Security

Requirements and Testing Procedures for Perimeter Enclaves, Ephemeral Credentials & Encryption

Standard Setter:	Payment Card Industry Security Standards Council (PCI SSC)
Specification ID:	PCI-DSS-V4.0-QRG
Classification:	Payment Card Data Protection Standard
Verification:	Integrated in Ariya Sarrafzadeh Production Architecture

1. 12 Principal Security Invariants

PCI DSS v4.0 mandates zero-trust security postures: firewall and network segmentation, non-default credentials, encrypted data in transit and at rest, anti-malware protections, secure SDLC, least-privilege RBAC, multi-factor authentication, physical isolation, continuous monitoring, and annual independent penetration tests.

2. Sensitive Authentication Data (SAD) Purge Invariant

Requirement 3.2 strictly prohibits storing CVV2/CVC2 card security codes, PIN blocks, or raw magnetic stripe data post-authorization. In our core architecture, ephemeral CVV2 codes maintain an absolute 0.00s zero-storage retention policy, held only in volatile memory during transit.

3. Opaque Token Vault & Scope Reduction

Primary Account Numbers (PAN) must be isolated within dedicated token vaults. Ingress gateways tokenize PANs into cryptographically random UUID tokens before reaching microservices, drastically shrinking the compliance audit perimeter.

4. E-Commerce Checkout Tamper Detection

Requirement 6.4.3 mandates strict inventory, verification, and integrity monitoring for all JavaScript libraries executing in payment checkout contexts to defeat client-side Magecart skimming attacks.

Systems Verification Notice: This authoritative specification establishes the invariant compliance baseline for production fintech switches, settlement reconciliation engines, and double-entry ledger implementations documented across the portfolio.